

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

The ESXiArgs ransomware attack is targeting VMware ESXi servers globally

Date of Publication

February 07, 2023

Admiralty Code

A1

TA Number

TA2023067

Summary

First Seen: December 2022

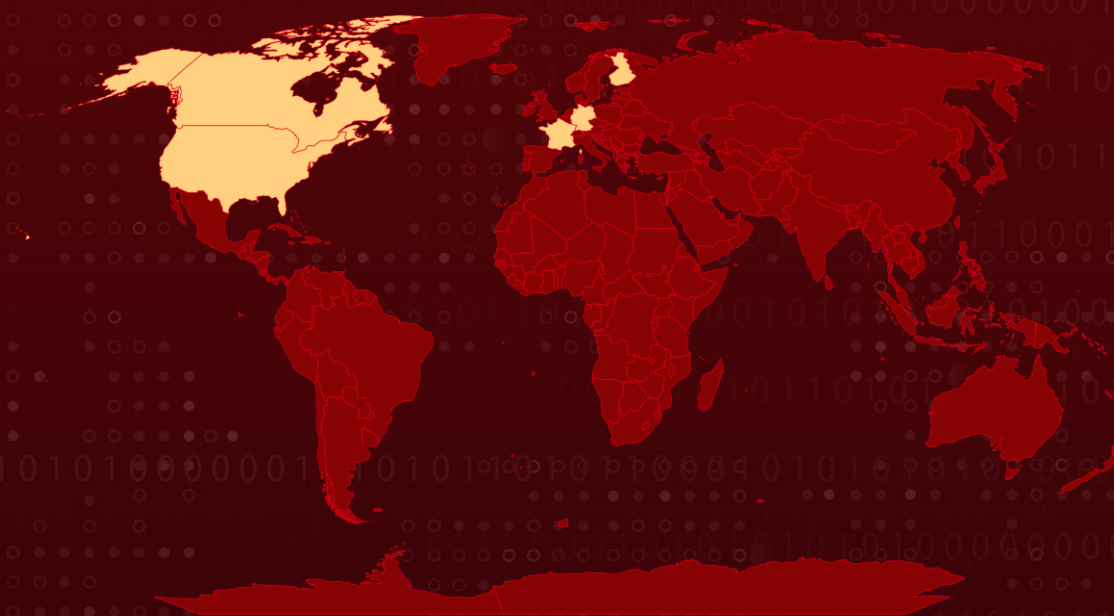
Affected Product: VMware ESXi, VMware vCenter Server (vCenter Server), and VMware Cloud Foundation (Cloud Foundation)

Attack Regions: France, Germany, Finland, the US, and Canada

Impact: The vulnerability allows for Remote code execution can lead to the attackers gaining control of the compromised system.



Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom



CVEs

CVE	NAME	PATCH
CVE-2021-21974	ESXi OpenSLP heap-overflow vulnerability	
CVE-2021-21973	SSRF vulnerability in the vSphere Client	
CVE-2021-21972	Remote code execution vulnerability in the vSphere Client	

Attack Details

#1

A global ransomware attack, known as ESXiArgs, is affecting servers using VMware ESXi hypervisors version 6.x prior to 6.7 due to a vulnerability (CVE-2021-21974) caused by a heap overflow issue in the Open Service Location Protocol (OpenSLP) service along with two additional vulnerabilities. This attack is expected to spread further.

#2

The attack exploits the vulnerability to allow remote code execution and has impacted servers in several countries, primarily developed nations. The attackers demand a ransom in bitcoins and the files are encrypted with the .vmxf, .vmx, .vmdk, .vmsd, and .nvram extensions. Admins are advised to disable the SLP service and apply the patch to prevent incoming attacks and perform a full system scan.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5’s Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the ‘Potential MITRE ATT&CK TTPs’ & ‘Indicators of Compromise (IoC)’ on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0005</u> Defense Evasion	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0004</u> Privilege Escalation
<u>TA0003</u> Persistence	<u>TA0042</u> Resource Development	<u>TA0040</u> Impact	<u>T1068</u> Exploitation for Privilege Escalation
<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1588.005</u> Exploits	<u>T1203</u> Exploitation for Client Execution
<u>T1509</u> Command and Scripting Interpreter	<u>T1486</u> Data Encrypted for Impact		

✂ Indicators of Compromise (IOCs)

TYPE	VALUE
SHA256	10c3b6b03a9bf105d264a8e7f30dcab0a6c59a414529b0af0a6bd9f1d2984459 11b1b2375d9d840912cfd1f0d0d04d93ed0cddb0ae4ddb550a5b62cd044d6b66
SHA1	25846f8cda8b0460e1db02ba6d3836ad3721f62 f25846f8cda8b0460e1db02ba6d3836ad3721f62
MD5	d0d36f169f1458806053aae482af5010 87b010bc90cd7dd776fb42ea5b3f85d3

✂ Patch Details

Upgrade to the latest version of ESXi

<https://www.vmware.com/security/advisories/VMSA-2021-0002.html>

✂ References

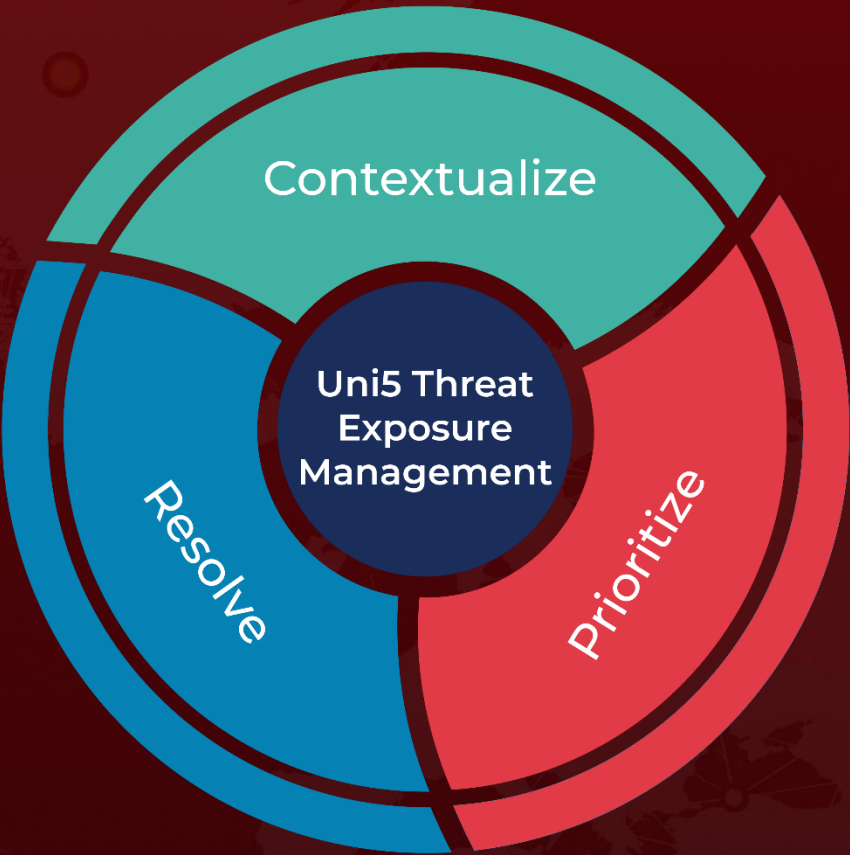
<https://www.csoonline.com/article/3687095/massive-ransomware-attack-targets-vmware-esxi-servers-worldwide.html>

<https://www.bleepingcomputer.com/news/security/massive-esxiargs-ransomware-attack-targets-vmware-esxi-servers-worldwide/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

February 7, 2023 • 11:40 PM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com